

TP — Analyse d'un protocole industriel vulnérable : Telnet sous Wireshark

Module Cybersécurité — GI-CNAM (ingénieurs par l'alternance) Durée : ≈ 2 h · Travail individuel ou en binôme · À rendre : vos réponses + vos filtres Wireshark

1. Mise en situation

Sur une cellule de production, un **poste d'ingénierie** (10.10.10.50) administre à distance un **équipement industriel** (10.10.10.1) — par exemple un automate, une passerelle ou un commutateur managé « legacy ». Cet équipement expose deux services d'administration : **Telnet** (TCP/23) et **SSH** (TCP/22).

Un attaquant présent sur le même segment réseau (poste compromis, port miroir mal configuré, prise réseau accessible en atelier...) a lancé une capture. Vous récupérez le fichier captures/capture_telnet_industriel.pcap et devez mener l'analyse *post-mortem*.

Rappel. Telnet est encore très répandu sur les équipements OT/ICS anciens, les RTU, certains onduleurs, caméras, imprimantes d'étiquettes et commutateurs industriels. Il transporte **tout en clair**, y compris les identifiants.

Objectifs

1. Reconstituer la session Telnet et en extraire l'identifiant **et le mot de passe réellement accepté**.
2. Montrer, par comparaison avec le flux SSH du *même* équipement, l'intérêt du chiffrement.
3. Proposer des contre-mesures réalistes dans un contexte industriel.

Matériel et logiciels

- captures/capture_telnet_industriel.pcap (fourni).
- Wireshark 4.4.x ou équivalent.
- (Optionnel) [CyberChef](#) pour la partie bonus.

⚠ **Cadre légal.** Capturer le trafic d'un réseau sans autorisation est un délit. La capture de ce TP est fictive, anonymisée et destinée au seul usage de laboratoire.

2. Prise en main de la capture

1. Ouvrez le fichier dans Wireshark.
2. Ouvrez **Statistics** → **Protocol Hierarchy**.

Q1. Quels protocoles sont présents, et dans quelles proportions (en octets) ? Jusqu'à quelle couche du modèle OSI Wireshark parvient-il à décoder chaque flux ?

3. Ouvrez **Statistics** → **Conversations**, onglet **TCP**.

Q2. Combien de conversations TCP distinctes observez-vous ? Pour chacune, relevez les adresses IP, les ports source/destination et le volume échangé. Laquelle correspond à une session d'administration *en clair* ? Justifiez à partir du numéro de port.

Q3. Les deux adresses IP sont sur le même sous-réseau. Rappelez le masque et la notation CIDR correspondants à `10.10.10.0/24`, et indiquez qui est, selon vous, l'équipement administré et qui est l'administrateur. Sur quel indice vous appuyez-vous ?

3. Le flux Telnet : couche transport

1. Appliquez le filtre d'affichage `tcp.port == 23`.
2. Repérez les 3 premiers paquets de la connexion.

Q4. Identifiez la **poignée de main en trois temps** (*three-way handshake*). Pour chacun des 3 paquets, donnez les drapeaux TCP positionnés (SYN, SYN/ACK, ACK) ainsi que les numéros de séquence et d'acquittement **bruts**. Expliquez la relation $ACK = SEQ \text{ reçu} + 1$ lors de l'établissement.

Q5. Activez l'affichage des numéros **relatifs** (déjà actif par défaut) puis désactivez-le (*Preferences → Protocols → TCP → Relative sequence numbers*). Pourquoi Wireshark propose-t-il par défaut des numéros relatifs ? En quoi est-ce une aide pour l'analyse ?

Q6. Combien d'octets de données utiles (*payload*) le poste d'ingénierie envoie-t-il réellement vers l'équipement, au total, sur toute la session Telnet ? (*Indice : construisez un filtre qui ne garde que les segments porteurs de données allant du poste vers l'équipement — voir l'annexe.*)

4. Reconstitution de la session (Follow TCP Stream)

1. Clic droit sur un paquet Telnet → **Follow** → **TCP Stream**.
2. Observez le dialogue reconstitué (une couleur par sens de communication).

Q7. Recopiez le déroulé complet de l'échange (invites de l'équipement et saisies du poste). Quel est l'**identifiant** utilisé ?

Q8. (question clé) Combien de **tentatives d'authentification** apparaissent dans la session ? Pour chacune, indiquez le mot de passe saisi **et la réponse de l'équipement**. En déduire : **quel est le mot de passe réellement validé** ?

Attention : le premier mot de passe lisible dans le flux n'est **pas** forcément le bon. Un·e analyste pressé·e qui se contente du premier secret trouvé se trompe de réponse. C'est précisément le point de vigilance de ce TP.

Q9. Sur quel message protocolaire vous appuyez-vous *objectivement* pour affirmer qu'une tentative a échoué et que l'autre a réussi ? Ce message fait-il partie du protocole Telnet lui-même, ou de l'application d'authentification au-dessus ? Discutez.

Q10. Dans Wireshark, le dissecteur telnet existe. Appliquez le filtre `telnet`. Voit-on des octets de **négociation d'options** Telnet (IAC, DO/DONT/WILL/WONT, caractère `0xFF`) dans cette capture ? Qu'est-ce que cela nous apprend sur la façon dont la session a été générée/simplifiée ?

5. Analyse de la robustesse du secret

Q11. Observez attentivement la *forme* des deux mots de passe saisis. Quel **motif de génération** reconnaissez-vous (indice : regardez la disposition des touches d'un clavier) ? En quoi l'un évoque-t-il un clavier **AZERTY** et l'autre un clavier **QWERTY** ? Pourquoi ce type de mot de passe (« *keyboard walk* ») est-il faussement rassurant et en réalité très faible ?

Q12. Estimez grossièrement l'entropie des deux secrets et classez-les. Un tel mot de passe résisterait-il à une attaque par dictionnaire enrichi de motifs clavier (règles *hashcat*, listes type *rockyou*) ? Justifiez.

Q13. (analyse temporelle) Ajoutez la colonne `tcp.time_delta` (ou utilisez la colonne *Time* en mode « Seconds Since Previous Displayed Packet »). Combien de temps s'écoule-t-il entre la tentative échouée et la tentative réussie ? Cet intervalle plaide-t-il plutôt pour une **erreur de frappe humaine** ou pour une **attaque automatisée par force brute** ? Qu'en concluez-vous sur le profil de l'auteur ?

6. Comparaison Telnet vs SSH sur le même équipement

Le même équipement expose aussi **SSH** (TCP/22). Les deux sessions sont dans la capture.

1. Appliquez `tcp.port == 22`, puis **Follow** → **TCP Stream** sur ce flux.

Q14. Que lisez-vous dans le flux SSH ? Pouvez-vous y retrouver l'identifiant ou le mot de passe comme pour Telnet ? Pourquoi ?

Q15. Même sur un flux **chiffré**, quelles informations restent-elles accessibles à un observateur passif (*métadonnées*) ? Citez-en au moins quatre (pensez aux couches basses, aux ports, au volume, au rythme des échanges). Comment appelle-t-on cette famille d'analyses qui n'a pas besoin de déchiffrer le contenu ?

Q16. Rédigez en deux phrases l'argument que vous présenteriez à un responsable de production réticent à « toucher à une machine qui marche », pour justifier le remplacement de Telnet par SSH.

7. Filtres d'affichage (entraînement)

Donnez le filtre Wireshark correspondant à chaque besoin. (*L'annexe A liste la syntaxe.*)

Q17. Ne garder que les segments Telnet **porteurs de données** venant du poste d'ingénierie.

Q18. Ne garder que les paquets de la poignée de main TCP (SYN et/ou SYN-ACK), tous flux confondus.

Q19. Afficher tout le trafic échangé avec l'équipement **10.10.10.1**, **sauf** le SSH.

Q20. Trouver, dans n'importe quel flux en clair, les paquets dont la charge utile contient la chaîne Success (indice : opérateur `contains` ou `matches`).

8. Contre-mesures (contexte OT/ICS)

Q21. Proposez un plan de remédiation **hiérarchisé** pour cet équipement. Classez vos mesures en trois niveaux : (a) immédiat / sans interruption de service, (b) court terme, (c) architecture. Pensez notamment à : désactivation de Telnet, usage exclusif de SSH, politique de mots de passe, segmentation réseau / VLAN / zones et conduits (norme **IEC 62443**), bastion d'administration, journalisation, MFA sur les accès d'administration.

Q22. En OT, on ne peut pas toujours patcher ni redémarrer librement (contraintes de **sûreté de fonctionnement** et de disponibilité). Quelles **mesures compensatoires** proposeriez-vous lorsqu'un équipement ne peut *pas* abandonner Telnet à court terme ?

Q23. (ouverture Industrie 4.0 / 5.0) Avec la convergence IT/OT, ces équipements se retrouvent de plus en plus connectés (supervision, cloud, IoT). En quoi cela aggrave-t-il le risque lié à un simple Telnet laissé actif ? Reliez votre réponse à la notion de *surface d'attaque*.

Bonus — CyberChef

Q24. Avec [CyberChef](#), encodez puis décodez l'un des mots de passe en Base64, et calculez son empreinte **SHA-256**. Un mot de passe « haché » dans une base de données est-il récupérable ? Qu'est-ce qui fait malgré tout la faiblesse d'un *hash* de mot de passe aussi simple (notion de *rainbow table*, de *sel*) ?

Livrable attendu

- Vos réponses Q1 → Q23 (+ Q24 bonus).
- Les **filtres** rédigés aux questions 6, 17 à 20 (copier/coller exact).
- Pour la question clé Q8 : l'identifiant **et** le mot de passe validé, avec la preuve (message de l'équipement) qui justifie votre choix.

Annexe A — Commandes et filtres Wireshark essentiels

expression de filtre = **filtre d'affichage** (barre verte), appliqué *après* la capture.
À ne pas confondre avec les **filtres de capture** (syntaxe BPF, définis *avant* de capturer).

A.1 — Opérateurs des filtres d'affichage

Opérateur	Alias	Signification	Exemple
==	eq	égal	ip.addr == 10.10.10.1
!=	ne	différent	tcp.port != 22
> <	gt lt	supérieur / inférieur	tcp.len > 0
>= <=	ge le	sup. ou égal / inf. ou égal	ip.ttl <= 64
&&	and	ET logique	ip.src==10.10.10.50 && tcp.port==23
	or	OU logique	tcp.port==22

Opérateur	Alias	Signification	Exemple
!	not	NON logique	 tcp.port==23 !(arp icmp)
contains	—	contient une suite d'octets/texte	frame contains "Success"
matches	~	correspond à une regex	http.host matches "\\..local\$"
in	—	appartient à un ensemble	tcp.port in {80 443 8080}
[n] [n:m]	—	accès par octet / tranche	eth.src[0:3] == 02:1c:10

A.2 — Filtres de capture (BPF, avant capture)

Filtre	Effet
host 10.10.10.1	trafic d'une machine
net 10.10.10.0/24	trafic d'un sous-réseau
port 23	un port précis
tcp port 22 or tcp port 23	plusieurs ports
not arp and not stp	exclure du bruit

A.3 — Filtres par protocole (les plus utiles)

Couche	Filtre	Décrit
Ethernet	eth.addr / eth.src / eth.dst	adresses MAC
	eth.type	type de protocole encapsulé
ARP	arp.opcode	requête (1) / réponse (2)
IPv4	arp.src.proto_ipv4	IP de l'émetteur
	ip.addr / ip.src / ip.dst	adresses IP
	ip.proto	protocole transporté (6=TCP, 17=UDP, 1=ICMP)
	ip.ttl	durée de vie
IPv6	ip.len	taille totale du paquet
	ipv6.addr / ipv6.src / ipv6.dst	adresses IPv6
TCP	tcp.port / tcp.srcport / tcp.dstport	ports
	tcp.flags.syn / tcp.flags.ack	drapeaux

Couche	Filtre	Décrit
	tcp.flags.fin tcp.flags.reset tcp.seq / tcp.ack	n° de séquence / acquittement
	tcp.len	taille de la charge utile TCP
	tcp.stream	identifiant de flux (pour isoler une session)
	tcp.analysis.retransmission	retransmissions détectées
	tcp.time_delta	temps depuis le paquet précédent du flux
UDP	udp.port / udp.length	ports / taille
ICMP	icmp.type / icmp.code	type / code de message
Telnet	telnet	isole le flux Telnet (dissecteur)
	telnet.data	données applicatives Telnet
SSH	ssh	isole le flux SSH
	ssh.protocol	bannière de version (si présente)
DNS	dns.qry.name	nom résolu
HTTP	http.request.method / http.request.uri http.authorization	méthode / URI en-tête d'authentification (souvent en clair !)
TLS	tls.handshake.type	étapes de la négociation TLS

A.4 — Filtres composés utiles (modèles)

Besoin	Filtre
Données d'un sens précis	ip.src==10.10.10.50 && tcp.port==23 && tcp.len>0
Poignées de main	tcp.flags.syn==1
SYN sans ACK (tentatives de connexion)	tcp.flags.syn==1 && tcp.flags.ack==0
Un flux et un seul	tcp.stream == 0
Exclure un service	ip.addr==10.10.10.1 && !ssh
Rechercher un texte en clair	frame contains "Success"
Resets (connexions refusées)	tcp.flags.reset==1

A.5 — Opérations graphiques clés

Menu / action	Usage
Clic droit → Follow → TCP/UDP Stream	reconstituer une session complète
Statistics → Protocol Hierarchy	répartition des protocoles
Statistics → Conversations	lister les échanges (IP/TCP/UDP)
Statistics → Endpoints	lister les hôtes
Statistics → I/O Graph	débit et rythme dans le temps
Clic droit → Apply as Column	transformer un champ en colonne
Clic droit → Apply/Prepare as Filter	générer un filtre depuis un champ
File → Export Objects → HTTP/SMB...	extraire des fichiers transférés
View → Coloring Rules	colorer selon des critères
Ctrl + /	aller dans la barre de filtre d'affichage

A.6 — En ligne de commande (tshark)

Commande	Effet
<code>tshark -r capture.pcap</code>	lister les paquets
<code>tshark -r capture.pcap -Y "tcp.port==23"</code>	appliquer un filtre d'affichage
<code>tshark -r capture.pcap -z conv,tcp -q</code>	statistiques de conversations TCP
<code>tshark -r capture.pcap -q -z io,phs</code>	hiérarchie des protocoles
<code>tshark -r capture.pcap -z follow,tcp,ascii,0 -q</code>	suivre le flux TCP n°0
<code>tshark -r capture.pcap -T fields -e ip.src -e tcp.dstport</code>	extraire des champs

Fin de l'énoncé.